Pontifícia Universidade Católica do Rio Grande do Sul
Escola Politécnica
Laboratório de Redes de Computadores

Interceptação e Defesa de um Protocolo de Aplicação

Trabalho de Laboratório de Redes de Computadores

Objetivo

O objetivo deste trabalho é entender, na prática, por que protocolos de aplicação sem proteção são vulneráveis. Em vez de construir um serviço seguro do zero, o grupo vai:

1. **montar seu próprio alvo** — um par cliente-servidor que se comunica por um protocolo de aplicação **em texto claro**, todo dentro de VMs do próprio grupo;
2. **implementar, com sockets raw, uma ferramenta de interceptação** que demonstra as fragilidades desse protocolo **dentro do laboratório isolado**;
3. **implementar a defesa** que neutraliza a interceptação e discutir a detecção do ataque.

O produto final não é uma "ferramenta de ataque" para uso geral — é uma prova de conceito em ambiente fechado cujo propósito declarado é fundamentar a defesa.

Descrição

O trabalho segue três fases que serão avaliadas individualmente para compor a nota da disciplina de Laboratório de Redes de Computadores. As Fases 1, 2 e 3 corresponderão respectivamente as notas T1, T2 e T3 da disciplina. As Fases e suas Entregas são descritas a seguir:

- **Fase 1 — Reconhecimento e escuta passiva:** o grupo deve montar o alvo e implementar um interceptador passivo (sniffer de aplicação) que lê o tráfego. Demonstra a quebra de confidencialidade.
- **Fase 2 — Interceptação ativa (MITM):** implementar um *proxy man-in-the-middle* que se posiciona entre cliente e servidor, capaz de ler e alterar mensagens, atendendo múltiplas conexões simultâneas. Demonstra a quebra de integridade e de autenticação.
- **Fase 3 — Defesa e detecção:** implementar a mitigação (canal seguro/autenticação) e mostrar que o mesmo ataque falha e analisar como o ataque poderia ser detectado.

As Fases serão entregues e apresentadas em datas distintas, conforme cronograma da disciplina discutido em aula.

FASE 1 – CRIAÇÃO DA APLICAÇÃO ALVO E DO SNIFFER DE TRÁFEGO

O grupo deve implementar um protocolo de aplicação próprio inseguro (texto claro, sem autenticação forte), ou reutiliza/simplifica um protocolo clássico em uma versão criada pelo grupo. Sugestões de serviço a ser protegido/atacado:

- **Login/autenticação simples** (cliente envia usuário e senha ao servidor em texto claro).
- **Chat/mensagens** sem cifragem.
- **Transferência de arquivos** sem integridade nem cifragem.
- **Comandos remotos** (cliente envia comandos a um servidor que os executa em um espaço controlado).
- **Repositório chave-valor** sem proteção.

O protocolo escolhido deve, na versão inicial, carregar informação sensível ou manipulável (credenciais, conteúdo de mensagens, comandos, valores), para que a interceptação tenha o que demonstrar e, na Fase 3, o que proteger.

Requisitos

1) Toda a comunicação e a interceptação usam sockets diretamente (sem frameworks que escondam o socket).

- Linguagem livre (recomenda-se Python pela clareza de sockets e da camada SSL/TLS).
- Wireshark pode ser usado como instrumento para monitoração de tráfego durante o seu desenvolvimento. No entanto, a aplicação deve implementar o seu próprio *sniffer* para a captura de pacotes, usando um *socket raw*.

2) O teste deve ser feito em ambiente virtual isolado. Monte a rede com, no mínimo, VM-cliente, VM-servidor e VM-observador.

- Serviço alvo: implementar cliente e servidor do protocolo escolhido.
- Interceptador passivo (sniffer de aplicação): implementar, com sockets/captura, uma ferramenta que lê o tráfego do protocolo e extrai a informação sensível (por exemplo, exibindo as credenciais ou o conteúdo das mensagens observadas).
- Evidência com Wireshark: capturar o tráfego e mostrar, pacote a pacote, que o conteúdo trafega legível.

Entregas da Fase 1

1) Código do serviço alvo

2) Código do interceptador passivo

3) Descrição do trabalho para execução em um README com a topologia.

4) Relatório demonstrando a leitura do conteúdo em texto claro, com evidência de captura (número dos pacotes).

FASE 2 — INTERCEPTAÇÃO ATIVA (Man-in-the-Middle)

A meta desta fase é criar um atacante/observador que deverá estar posicionado entre cliente e servidor e demonstrar a quebra de integridade e autenticação, atendendo múltiplas conexões simultâneas.

Requisitos

1. **Proxy MITM com sockets:** implementar um intermediário que aceita a conexão do cliente, abre a conexão ao servidor e executa o relay das mensagens nos dois sentidos. O redirecionamento do tráfego para o proxy deve ser feito por configuração do próprio serviço, por exemplo, apontando o cliente ao proxy.
2. **Leitura e modificação controlada:** o proxy deve ser capaz de inspecionar e alterar mensagens em trânsito (por exemplo, modificar um valor, um comando ou uma resposta), evidenciando que, sem integridade/autenticação, o conteúdo pode ser adulterado sem detecção.
3. **Concorrência:** o proxy deve atender múltiplas conexões/sessões simultâneas.
4. **Robustez:** lidar com desconexões e mensagens malformadas sem derrubar as demais sessões.
5. **Evidência:** demonstrar, com captura e com a saída do proxy, uma alteração de mensagem que o cliente/servidor aceita como legítima.

Entregas da Fase 2

1) Código do proxy MITM concorrente;

2) Descrição do trabalho para execução em um README com a topologia de redirecionamento.

3) Documento explicando o modelo de concorrência e as regiões críticas.

4) Demonstração de leitura e modificação de mensagens, com evidência.

FASE 3 — DEFESA E DETECÇÃO

A meta nesta fase é neutralizar o ataque das fases anteriores implementando a proteção adequada, e mostrar que a interceptação deixa de funcionar.

Requisitos

1. **Confidencialidade e integridade:** proteger o canal do serviço alvo — recomenda-se **TLS** sobre o socket TCP (camada ssl/OpenSSL). Após a mudança, o interceptador passivo da Fase 1 não deve mais conseguir ler o conteúdo.
2. **Autenticação:** autenticar as pontas — no mínimo o servidor via certificado (para impedir o MITM se passar por servidor) e/ou o usuário via credenciais protegidas (senhas com *hash*, nunca em texto claro). Após a mudança, o proxy MITM da Fase 2 não deve

mais conseguir modificar mensagens sem ser detectado (a validação de certificado/integridade acusa a adulteração).

3. **Prova antes/depois com Wireshark:** capturar o tráfego do serviço **antes** (texto claro, Fases 1–2) e **depois** (protegido, Fase 3), evidenciando que o conteúdo antes legível tornou-se ilegível e que o MITM passou a falhar.
4. **Análise de ameaças e detecção:** descrever quais ameaças a defesa mitiga (sniffing, MITM, adulteração, e — se aplicável — ataque de replay) e como um defensor detectaria a tentativa de ataque (por exemplo, erros de validação de certificado no cliente, alertas de handshake, anomalias observáveis).
5. **Limitações:** discutir o que a defesa escolhida não cobre (por exemplo, metadados ainda visíveis, ataques fora do escopo).

Entregas da FASE 3

1) Código do serviço alvo protegido.

2) Descrição do trabalho para execução em um README (incluindo geração/instalação de certificados).

3) Demonstração de que o interceptador passivo e o proxy MITM das fases anteriores falham contra a versão protegida.

4) Capturas Wireshark comparativas antes/depois.

5) Relatório final consolidado das três fases com as análises solicitadas.

Informações Gerais

- Grupo: até 3 alunos
- Entregas: entrega de documentos no Moodle
- Datas de Entregas e Apresentações:

Fase	Data	Marco
Fase 1 — Aplicação e Escuta	05/10/2026	Entrega 1 sem apresentação
Fase 2 — MITM concorrente	26/10/2026	Entrega 2 com demo de modificação
Fase 3 — Defesa e detecção	23/11/2026	Entrega 3 com defesa final

Composição das notas por fase

Cada fase vale de 0 a 10, formando uma nota individual para cada fase do trabalho. A cada fase, as notas de fases anteriores não serão revistas e/ou reconsideradas. Caso o trabalho

falhe na fase 1, deverá ser refeito para que a fase seguinte tenha sucesso, mas isso não implicará na reconsideração da fase que já foi analisada e avaliada.

A nota final da disciplina, segue a média aritmética simples, conforme previsto no Plano de Ensino:

$$G1 = (T1+T2+T3)/3$$

A disciplina é uma disciplina de avaliação especial, não tem prova G2 e sua média de aprovação é 5,0.